

КОНФИДЕНЦИАЛЬНО

ТЕХНИЧЕСКОЕ ОПИСАНИЕ СИСТЕМЫ

Назначение, возможности, устройство и защита информации

Версия документа: 1.62

Дата: 15.08.2026

Экземпляр передан: Акционерное общество «Холдинговая компания „Остров Мечты“»
(ИНН 9725171970)

© 2026 Мякотных Сергей Михайлович. Все права защищены.

УСЛОВИЯ ИСПОЛЬЗОВАНИЯ ДОКУМЕНТА

Правообладатель: Мякотных Сергей Михайлович

Получатель: Акционерное общество «Холдинговая компания „Остров Мечты“» (ИНН 9725171970)

1. Правообладатель. Исключительное право на настоящий документ и на описанную в нём систему, включая её исходный код и интерфейсы, принадлежит правообладателю. Передача документа не влечёт перехода к Получателю прав на систему или её составные части.

2. Передача третьим лицам. Документ, его части и производные материалы - копии, выдержки, переводы, презентации, снимки экрана - не передаются третьим лицам без согласия правообладателя. Внутри организации Получателя документ доводится до работников, которым он необходим для работы с системой.

3. Отсутствие лицензии. Документ описывает систему и не является офертой или лицензией на её использование. Право использования системы возникает на основании отдельного договора с правообладателем.

© 2026 Мякотных Сергей Михайлович. Все права защищены.

СОДЕРЖАНИЕ

1. Общие сведения.....	5
1.1. Назначение документа.....	5
1.2. Состав документации.....	5
1.3. Область применения.....	6
1.4. Оформление.....	6
2. Термины и сокращения.....	6
3. Назначение системы.....	7
3.1. Решаемые задачи.....	7
3.2. Границы применения.....	8
4. Пользователи системы.....	8
4.1. Типы учётных записей.....	8
4.2. Разграничение доступа.....	9
5. Жизненный цикл заявки.....	11
5.1. Порядок обработки.....	11
5.2. Проверка по чёрным спискам.....	15
5.3. Прозрачность обработки.....	16
6. Функциональные возможности.....	18
6.1. Файловый архив бланков.....	19
6.2. Уведомления.....	23
6.3. Массовый ввод участников из бланка.....	25
7. Поиск и работа с накопленными данными.....	27
7.1. Поиск, устойчивый к способу ввода.....	27
7.2. Приведение сведений к единому виду.....	29
7.3. Повторное использование ранее заведённых сведений.....	29
7.4. Скорость поиска при накоплении данных.....	30
8. Обучение работе с системой.....	30
8.1. Обучающие туры.....	30
8.2. Встроенное руководство.....	31
8.3. Сообщение о сбое.....	31
9. Устройство системы.....	32

9.1. Состав частей.....	32
9.2. Технологическая основа.....	33
9.3. Фоновые задачи.....	33
10. Организация данных.....	35
10.1. Состав базы данных.....	35
10.2. Сохранность исторических сведений.....	36
10.3. Поиск по большим объёмам.....	37
11. Программный интерфейс.....	37
12. Обновление данных без перезагрузки.....	39
13. Защита информации.....	39
13.1. Проверка подлинности.....	39
13.2. Разграничение доступа.....	44
13.3. Вход от имени другого работника.....	45
13.4. Защита передаваемых данных.....	47
13.5. Защита от типовых атак.....	47
13.6. Защита персональных данных при хранении.....	48
13.7. Учёт обращений к персональным данным.....	50
13.8. Согласия на обработку персональных данных.....	50
13.9. Журналы и прослеживаемость.....	53
13.10. Автоматический контроль защищённости.....	54
14. Тестирование и обеспечение качества.....	55
14.1. Уровни тестирования.....	55
14.2. Что дают тесты при сопровождении.....	56
14.3. Автоматический конвейер сборки и проверки.....	57
14.4. Проверочный стенд.....	58
15. Масштаб системы.....	58
Приложение А. Категории прав доступа.....	59

1. Общие сведения

1.1. Назначение документа

Документ описывает систему электронной подачи заявок «Бюро пропусков»: какие задачи она решает, как устроена работа пользователей, из каких частей состоит и какими средствами защищены обрабатываемые в ней сведения.

Документ предназначен для знакомства с системой перед вводом в эксплуатацию и для понимания её устройства в целом. Порядок установки и сопровождения вынесен в отдельный документ, «Руководство по развёртыванию и сопровождению».

1.2. Состав документации

Таблица 1.1 — Состав эксплуатационной документации

Документ	Кому адресован	Содержание
Техническое описание системы	Руководители, специалисты ИТ и защиты информации	Настоящий документ: назначение, возможности, устройство, защита информации
Руководство по развёртыванию и сопровождению	Подразделение информационных технологий	Требования, установка, настройка, эксплуатация, диагностика
Руководство пользователя	Заявитель	Подача заявок, свои справочники, личный кабинет
Руководство согласующего	Работник, чьё решение требуется для одобрения заявки	Рассмотрение заявок, решение по согласованию, вопросы заявителю
Руководство принимающего	Сотрудник бюро пропусков, ведущий заявки	Приём заявки в работу, назначение постов и мест, дополнения
Руководство администратора	Сотрудник бюро пропусков с правами администратора	Учётные записи, права, справочники, таблицы постов, аудит
Руководство охранника	Сотрудник поста	Работа с таблицами поста, отметка прохода, проверка пропуска

Описание программного интерфейса формируется автоматически из исходного кода и доступно в работающей системе.

1.3. Область применения

Система предназначена для организации пропускного режима на территории предприятия: оформления, согласования и учёта заявок на проход людей, проезд транспорта, внос и вынос материальных ценностей, а также для контроля фактического нахождения людей и транспорта на территории.

1.4. Оформление

Команды, имена файлов и параметры набраны моноширинным шрифтом. Таблицы, рисунки и примеры команд нумеруются по разделам. Угловые скобки означают подстановку: <домен> заменяется фактическим значением без скобок.

Отдельно выделяются сведения, требующие повышенного внимания:

ПРИМЕЧАНИЕ. Так оформляются пояснения, которые полезно знать, но которые не влияют на порядок действий.

ВАЖНО. Так оформляются сведения, пропуск которых приведёт к неверной работе или к лишней работе по исправлению.

ОПАСНО. Так оформляются действия, последствия которых необратимы: утрата данных или утрата доступа к ним.

2. Термины и сокращения

Таблица 2.1 — Термины, применяемые в документе

Термин	Значение
Заявка	Электронный документ на доступ на территорию: кто проходит, что проезжает, что вносится, на какой срок и куда
Вложение	Часть заявки, объединяющая однородные объекты: людей, транспорт либо материальные ценности. В одной заявке их может быть несколько, с разными сроками и местами
Бланк	Печатная форма по заявке, заполняемая системой по загруженному шаблону электронной таблицы
Пост, проходная	Точка контроля доступа, за которой закреплены перечни допущенных объектов
Таблица поста	Настраиваемый перечень допущенных людей либо транспорта, с которым работает охрана

Термин	Значение
Место разгрузки	Площадка, к которой привязывается вложение заявки на внос или ввоз ценностей
Чёрный список	Перечень людей и транспорта, которым доступ запрещён
Территориальный статус	Признак нахождения человека или транспорта на территории, изменяется отметками въезда и выезда
Согласующий	Работник, чьё решение требуется для одобрения заявки
Принимающий	Работник бюро, принявший заявку в работу и отвечающий за её обработку
Супер-администратор	Единственная учётная запись с полным доступом, включая режим технических работ
Персональные данные	Сведения о людях: фамилия, имя, отчество, документ, удостоверяющий личность, гражданство
Маркер доступа	Электронный пропуск в саму систему: короткая строка, которую браузер прикладывает к каждому обращению вместо повторного ввода пароля. Действует 15 минут, затем продлевается автоматически
Сертификат	Электронный документ, которым сервер подтверждает браузеру свою подлинность. Обеспечивает работу по защищённому соединению, тот самый «замок» в адресной строке
Поток событий	Механизм, которым сервер сообщает открытым страницам об изменениях, чтобы данные обновлялись без нажатия кнопки обновления

3. Назначение системы

3.1. Решаемые задачи

Система предназначена для ведения пропускного режима в электронном виде: оформления заявок на доступ, их согласования, учёта фактического прохода и хранения связанных сведений.

Таблица 3.1 — Задачи, решаемые системой

Задача	Как решается
Передача заявки между участниками	Заявка доступна бюро сразу после отправки. Согласующие работают с ней в системе, передавать документ физически не требуется
Отслеживание состояния заявки	Заявитель видит текущий статус и историю изменений, не обращаясь к бюро
Сохранность сведений	Данные хранятся в базе. Записи справочников не удаляются, а переводятся в архив, поэтому заявки прошлых периодов остаются читаемыми
Поиск по накопленным данным	Поиск по части слова, с учётом раскладки клавиатуры и латинского написания. Подробнее в разделе 7

Задача	Как решается
Единая картина по всем постам	Посты работают с общими данными. Отметка о въезде видна остальным без задержки
Учёт обращений к персональным данным	Каждое обращение записывается в отдельный журнал. Подробнее в подразделе 13.7
Контроль запретов на доступ	Объекты заявки сверяются с чёрными списками при подаче, в том числе с учётом подмены символов. Подробнее в подразделе 5.2
Защита от повторов во вложении	Один человек и одна машина попадают во вложение только раз: повтор отклоняют и форма подачи, и сервер. Подробнее в разделе 6

3.2. Границы применения

Система обеспечивает оформление, согласование и учёт доступа. Она не управляет исполнительными устройствами: шлагбаумами, турникетами и замками. Отметка о проходе вносится работником поста.

4. Пользователи системы

4.1. Типы учётных записей

В системе заведено шесть типов учётных записей. Тип носит справочный характер и служит для классификации работников. Он не определяет, что работник может делать: объём полномочий задаётся ролями и группами прав, поэтому два работника одного типа могут иметь разный доступ, а работники разных типов - одинаковый.

Единственное, на что тип влияет напрямую, - круг получателей заявки: работника с типом «Руководитель» вправе выбрать получателем любой заявитель, в какой бы организации тот ни работал. Подробнее в подразделе 4.2.

Таблица 4.1 — Типы учётных записей

Тип
Пользователь
Арендатор
Подрядчик
Охранник
Руководитель
Бюро пропусков

Типы создаются и редактируются администратором, перечень не является закрытым.

ПРИМЕЧАНИЕ. Настройку системы через интерфейс (справочники, таблицы постов, права, учётные записи) ведут сотрудники бюро пропусков под учётной записью с соответствующими правами. Порядок этих действий описан в руководстве администратора.

4.2. Разграничение доступа

Права вычисляются по четырёхуровневой модели. Уровни рассматриваются по порядку, первый подходящий определяет результат.

1. Заблокированный работник не имеет прав вообще, независимо от назначенных ролей.
2. Супер-администратор имеет полный доступ, включая режим технических работ и назначение прав администратора. Такая учётная запись в системе одна, это ограничение поддерживается принудительно.
3. Администратор имеет полный доступ, кроме действий супер-администратора и кроме персональных запретов.
4. Обычный работник получает права из назначенной роли, групп прав этой роли и персонально назначенных групп. Затем применяются персональные исключения, причём запрет имеет приоритет над разрешением.

Приоритет запрета позволяет закрыть конкретному работнику отдельное действие, не разрушая назначенную ему роль и не создавая роль на одного человека.

Каталог прав содержит 56 фиксированных ключей в семи категориях. Дополнительно на каждую созданную таблицу поста автоматически создаётся десять прав: просмотр, отметка въезда, отметка выезда, карточка объекта, история, версии, выгрузка, отчёт по проходам, корзина, удаление. Заводить права для новой таблицы вручную не требуется.

Разделы администрирования закрыты каждый своим правом, и вложенности между ними нет: право на раздел администрирования само по себе не открывает ни справочники, ни учётные записи, ни настройки, ни журнал обращений к персональным данным, ни файловый архив, ни конструктор таблиц постов. Каждое из этих прав назначается отдельно, поэтому работник, ведущий справочники, получает справочники и ничего сверх них. Администраторов и супер-администратора это не касается: они проходят по признаку учётной записи, а не по перечню ключей, и отдельные права круг их возможностей не сужают.

Отдельными правами закрыты действия, которые не сводятся к доступу на экран: выгрузка заявок, согласование, пересылка, дополнение поданной заявки, массовый ввод участников из бланка, блокировка учётной записи, вход в систему от имени другого работника, смена паролей всем работникам. Последнее отделено от права на раздел настроек намеренно: правка контактного телефона бюро и сброс паролей всей организации - действия разного веса, и второе не должно доставаться каждому, кому разрешено первое. Назначаются они независимо от прав на разделы, поэтому круг работников, которым разрешено, например, дополнять свои заявки, задаётся отдельно от круга тех, кто эти заявки видит. Право не отменяет проверок по существу дела: дополнить заявку разрешено её автору, и наличие права на чужую заявку не распространяется - кроме супер-администратора, для которого таких границ нет нигде.

Право «Вход от имени пользователя» стоит особняком и среди них: оно не открывает ни экрана, ни отдельного действия, а позволяет администратору работать в системе от имени другого работника, не зная его пароля. Что при этом разрешено, что закрыто и как это видно в журнале, описано в подразделе 13.3.

Так же устроена пересылка заявки. Передать её дальше вправе тот, кому она видна по делу: заявитель, работник бюро, принявший её в работу, назначенный ответственный или согласующий и тот, кому заявку открыли на

просмотр. Супер-администратор границ не имеет и здесь. Работник, которому заявку открыли только на просмотр, передаёт её дальше тоже только на просмотр: назначить по ней согласующего или ответственного вправе тот, кто за заявку отвечает.

Отказы в доступе записываются в журнал: работник, запрошенное действие, время. Это позволяет отличить неверно настроенные права от попытки обойти ограничения.

5. Жизненный цикл заявки

5.1. Порядок обработки

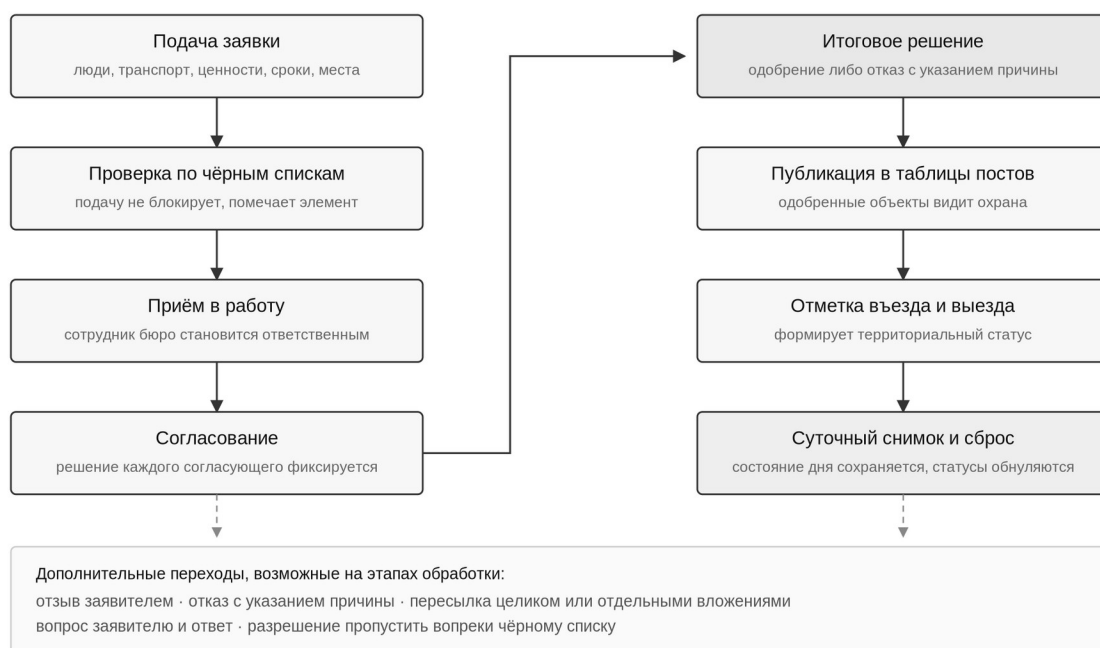


Рисунок 5.1 — Порядок прохождения заявки

Заявитель заполняет заявку: указывает организацию, добавляет вложения по людям, транспорту и ценностям, задаёт сроки и места, при необходимости прикладывает файлы, подтверждает согласие на обработку персональных данных и отправляет.

При отправке объекты заявки сверяются с чёрными списками. Порядок сверки описан в подразделе 5.2.

Заявка попадает в центр заявок. Сотрудник бюро принимает её в работу и становится ответственным. При необходимости назначаются согласующие, решение каждого фиксируется отдельно. Обработчик может задать заявителю вопрос и получить ответ, не выходя из карточки заявки, а также переслать заявку целиком или отдельными вложениями в другое подразделение.

Круг тех, кому заявку показывают, ограничен и при подаче, и при пересылке. Получателей заявитель выбирает из работников своей организации, работников своей компании и руководителей; тот же круг проверяется на сервере, поэтому назвать получателем постороннего в обход формы нельзя, а лишний идентификатор в запросе отбрасывается, не отменяя подачу целиком. При пересылке ограничение действует так же, кроме супер-администратора и работника бюро, принимающего заявки: маршрутизация заявок по чужим организациям и есть его работа, и круг собственных коллег здесь только помешал бы.

Обязательность согласования устроена по тому же справочнику, но по другому признаку. Обязательным согласующим заявки становится не тот, кого выбрал заявитель, а тот, у кого в карточке организации или компании стоит соответствующая отметка: форма подачи такого выбора вообще не предлагает, она лишь показывает, кто из ответственных отмечен как обязательный, и подаёт заявку с тем составом, который в этот момент прочитан из справочника. Работник, не входящий в состав организации или компании, обязательным согласующим не становится ни при каких условиях, а список, присланный вместе с заявкой в обход формы, сервер только сверяет с составом справочника - назначить им обязательность нельзя, для этого список и не предназначен. При расхождении заявка не создаётся с урезанным составом согласующих: подача отклоняется целиком, и заявитель получает отказ вместо заявки, поданной не в том виде, в каком он её отправлял.

Здесь и разница с получателями заявки, о которых сказано абзацем выше. Лишнего получателя система отбрасывает и заявку всё равно подаёт:

получатель заявку только просматривает, и один посторонний в списке ничего не решает. С обязательным согласующим так поступить нельзя - он голосует, и от его решения зависит исход заявки, поэтому посторонний в этом списке не отбрасывается молча, а останавливает подачу целиком.

Заявка, застрявшая на согласовании, не теряется: если решения ждут дольше заданного срока, система сама напоминает молчащему согласующему уведомлением и повторяет напоминание с заданной периодичностью. Оба срока и само напоминание задаются в разделе «Настройки». Доступ к нему закрыт отдельным правом: администраторы получают его вместе с остальными правами администрирования, а конкретному работнику оно снимается персональным запретом - так общесистемные значения отделяются от ведения справочников, не заводя ради этого отдельной роли. По умолчанию первое напоминание уходит через трое суток и повторяется каждые трое. Когда у заявки есть обязательные согласующие, напоминания получают только они - голос остальных на исход всё равно не влияет.

После завершения обработки одобренные объекты попадают в таблицы соответствующих постов и становятся видны охране. Работник поста отмечает фактический въезд и выезд, эти отметки формируют территориальный статус и историю проходов.

Уже поданную заявку разрешено дополнить, не подавая новую: заявитель добавляет людей, транспорт или ценности в существующее вложение. Дополнение закрыто отдельным правом: подать заявку может любой работник системы, а добавить в уже поданную - только тот, кому это право назначено. Одного права при этом мало, дополнить можно лишь собственную заявку; исключение - супер-администратор, он дополняет любую, как и в остальных действиях системы. Сама заявка должна оставаться действующей: непрочитанную, взятую в обработку и находящуюся в работе дополнить можно, завершённую, отклонённую и отозванную нельзя. Нельзя добавить и в то вложение, чей срок уже истёк.

Одновременно по заявке идёт не больше одного дополнения; следующее подаётся после решения по предыдущему.

Дальше порядок расходится надвое, и разделяет его то, выпущены ли объекты заявки на посты. Пока заявка не принята в работу, на проходной по ней никого нет, и добавленное просто становится частью её состава: решения согласующих отменяются, круг согласования начинается заново, теперь уже по дополненному составу. Отдельного решения по такой добавке не выносятся, и дальше она ничем не отличается от того, что было подано изначально: когда заявку принимают в работу, добавленные люди и машины встают на посты вместе с исходным составом и попадают в тот же бланк.

Заявку, уже принятую в работу, на повторное согласование не возвращают. Её люди и машины стоят на постах по выданным пропускам, и откат заявки снял бы с проходной всех, кого туда пустили, из-за нескольких добавленных строк. Поэтому добавка проходит собственный круг, отдельный от заявки: согласуют его те же ответственные, что назначены по заявке, а решение выносит принимающий, как и по самой заявке. Статус заявки и её согласование при этом остаются прежними, ранее допущенные люди и машины продолжают проходить по своим пропускам, и работа поста идёт своим чередом.

Строки такого отдельного дополнения до решения по нему на посты не выходят: охрана их не видит, в бланк пропуска они не попадают и в таблицах постов не значатся. Заявителю и согласующим они в карточке заявки видны, но помечены как ожидающие решения. Принятое дополнение выпускает свои строки на посты сразу: они встают в таблицы постов, попадают в бланк вложения и с этого момента видны охране. Отказ принимающего и снятие добавки самим заявителем закрывают её окончательно, добавленные строки так и остаются недопущенными. Отказ согласующего останавливает добавку, но обратного пути не отрезает: согласующий вправе отозвать свой голос, и тогда круг по добавке открывается заново - при условии, что заявка всё ещё принимает дополнения и другого незакрытого дополнения по ней не

появилось. Заккрытие самой заявки снимает и незакрытое дополнение по ней, чтобы оно не осталось у согласующих задач без исхода.

Ход дополнения не остаётся незамеченным. Подача зовёт согласующих, прохождение круга зовёт принимающих, а решение приходит заявителю. Сообщение об исходе дополнения отделено от сообщений о статусе заявки намеренно: статус заявки решением по добавке не двигается, и общее уведомление о заявке ввело бы заявителя в заблуждение.

Ежесуточно в заданное время система сохраняет снимок состояния таблиц и обнуляет территориальные статусы, чтобы новый день начинался с чистого листа, а состояние предыдущего оставалось доступным для разбора.

5.2. Проверка по чёрным спискам

Сверка выполняется при отправке заявки и работает на двух уровнях.

Точное совпадение. Если объект заявки совпадает с действующей записью чёрного списка, заявка не принимается, а заявитель получает отказ с пояснением.

Близкое совпадение. Сравнение выполняется не по исходной строке, а по приведённой к единому виду, поэтому обнаруживаются варианты, которыми точное сравнение обойти легко: подмена русских букв внешне похожими латинскими, замена буквы «О» на ноль в номере, опечатка, отсутствие отчества. Такой объект помечается признаком возможного совпадения с указанием, с какой записью и насколько близко он совпал.

Пометка не блокирует подачу, но **блокирует согласование заявки** до тех пор, пока по каждому помеченному объекту не будет принято явное решение пропустить его вопреки запрету. Пометка действует ровно столько, сколько действует запрет, на который она ссылается: снятая с учёта запись гасит её сама, и заявка согласуется без такого решения. Такое решение фиксируется отдельной записью с указанием принявшего его работника, поэтому ответственность за пропуск персонализирована.

Повторные предупреждения по той же паре «объект и запись чёрного списка» после принятого решения не выводятся.

Решение по помеченному объекту принимает согласующий заявки либо принимающий - кто первым дошёл до заявки; отменить принятое решение вправе оба. Помимо пропуска, у принимающего есть второй путь: убрать объект из поданной заявки, указав причину. Он предусмотрен для случая, когда пропуск неприемлем: без него помеченный объект держал бы заявку целиком, и единственным выходом был бы отказ по ней. Объект при этом перестаёт действовать и уходит из перечней постов, но остаётся в заявке и в её истории - заявка сохраняется как документ.

Внесение объекта в чёрный список действует и на уже оформленные данные: совпадающие люди и транспорт перестают действовать и исключаются из перечней постов, а в заявках остаются с отметкой о запрете. Перед внесением система показывает работнику, где объект фигурирует: сколько действующих записей перестанет действовать, из каких перечней постов они уйдут и в каких заявках встречаются. Перечень считается по тем же правилам, по которым выполняется само исключение.

5.3. Прозрачность обработки

Заявитель в любой момент видит текущее состояние заявки и историю её изменений: когда принята в работу, кто ответственный, какие решения приняли согласующие, по какой причине отказано. Обращаться за этими сведениями к бюро не требуется.

Дополнения заявки прослеживаются так же и в той же истории, отдельного журнала для них нет. Записью отмечается подача дополнения, голос каждого согласующего и отзыв голоса, прохождение круга согласования, принятие, отказ принимающего и снятие добавки. У каждой такой записи проставлен номер дополнения, поэтому в заявке с несколькими добавками видно, к какой из них относится решение. Состав добавки, её автор, пояснение и голоса по ней показаны в карточке заявки отдельным

блоком, а сами добавленные строки помечены в составе вложения, и по пометке видно, допущены они уже на посты или ещё ждут решения.

Отметки прочтения ведутся персонально: система различает, кто именно из имеющих доступ работников открывал заявку, а не только факт открытия.

Состав участников заявки виден одним списком: заявитель, работник бюро, принявший её в работу, согласующие с их решениями, ответственные и те, кому заявку открыли на просмотр. На каждом показаны должность, организация и компания, а также рабочие контакты - почта и телефон, - чтобы связаться с человеком по заявке, не запрашивая его адрес у бюро. Список доступен участникам этой же заявки; тому, кто заявку не видит, система отвечает отказом. Работник, не подтвердивший согласие на обработку персональных данных, показан в списке скрытым и без контактов, см. подраздел 13.8.

Перечень заявок за период выгружается из центра заявок в электронную таблицу: номер и дата подачи, организация и компания, заявитель, состояние заявки и её согласования, кто принял в работу, число людей и машин, границы срока действия, отметки чёрного списка и наличие приложенных файлов. В файл уходит ровно та выборка, что отображена на экране: заданный период, справочники, состояние, режим архива. Выгрузка закрыта тем же правом, что скачивание бланка одной заявки, и подчиняется тем же границам видимости - работник получает в файле только те заявки, которые видит в системе. Фамилии тех, кто не подтвердил согласие на обработку персональных данных, заменяются в файле именем учётной записи так же, как на экране, см. подраздел 13.8. Обращение к выгрузке учитывается в журнале обращений к персональным данным, см. подраздел 13.7.

6. Функциональные возможности

Таблица 6.1 — Функциональные подсистемы

Подсистема	Возможности
Заявки	Создание, приём в работу, согласование, завершение, отказ, отзыв. Дополнение уже поданной заявки со своим кругом согласования. Пересылка целиком и по вложениям, вопросы и ответы, история статусов, персональные отметки прочтения, напоминания молчащим согласующим
Вложения и бланки	Группировка объектов внутри заявки, настраиваемые дополнительные поля, шаблоны печатных форм с привязкой к ячейкам таблицы, формирование заполненного бланка. Выгрузка бланков в файловый архив на диске. Длинный перечень переносится на следующую страницу вместе со своей шапкой столбцов, поэтому многостраничный бланк остаётся читаемым. Заполненный бланк принимается обратно и наполняет список участников заявки, см. подраздел 6.3
Транспорт	Реестр транспортных средств, привязка к заявкам и постам, отметки въезда и выезда, история проездов, добавление вне заявки
Люди	Реестр физических лиц, документы, гражданство, история проходов, прикрепление файлов
Чёрные списки	Раздельные перечни по людям и транспорту, проверка при подаче, признак возможного совпадения, разрешение пропуска вопреки запрету с фиксацией
Таблицы постов	Конструктор перечней: настраиваемые столбцы, фотографии, временные интервалы, корзина удалённых записей, суточные снимки, выгрузка
Места разгрузки	Справочник площадок, фотографии, расписания, привязка к организациям
Организации и компании	Структура арендаторов и подрядчиков, ответственные лица, привязка ресурсов, групповые операции
Аналитика и отчёты	Панель показателей, конструктор отчётов, сохраняемые шаблоны, сводные таблицы, выгрузка в электронную таблицу
Права доступа	Роли, группы прав, персональные исключения, журнал отказов
Учётные записи	Заведение, блокировка, снятие блокировки входа после неудачных попыток, журнал входов, признак нахождения в системе и давность последнего входа, групповые операции. Смена собственного пароля работником, смена пароля отдельному работнику с отправкой письмом, обновление паролей всем работникам, требование сменить пароль по истечении срока его действия, отбор учётных записей без указанного адреса почты
Принимающие заявки	Перечень работников, которым можно передать заявку в работу, и отображаемое имя, под которым заявитель видит принявшего
Новости и объявления	Публикации с форматированным текстом и изображениями, объявление-баннер на главной
Уведомления	События по заявкам, срокам действия пропуска, учётной записи, новостям и обращениям. Доставляются без обновления страницы, повторы одного события собираются в одну запись, набор настраивается работником под себя. Подробнее в подразделе 6.2
Справочники	Гражданства, марки транспорта, форматы регистрационных знаков, типы вложений, типы работников, документы, режим работы бюро

Подсистема	Возможности
Обратная связь	Обращения работников со статусами, отправка сообщения о сбое
Обучение	Встроенное руководство по ролям и обучающий тур по интерфейсу. Подробнее в разделе 8
Обработка данных	Документ и текст согласия на обработку персональных данных, его редакция, требование согласия при входе и ход сбора. Подробнее в подразделе 13.8
Журналы и режим работ	Журнал запросов, сводный журнал изменений, журнал обращений к персональным данным, режим технических работ
Файловый архив	Выкладывание сформированных бланков на диск сервера, раскладка файлов, занятое место, ошибки записи, выгрузка задним числом. Подробнее в подразделе 6.1

Одного человека и одну машину вложение принимает только один раз: повтор отклоняют и форма подачи, и сервер. Людей система различает по паспортным данным, а когда шаблон вложения их не запрашивает - по фамилии, имени и отчеству; машины - по государственному номеру, поэтому одна машина под разными марками повтором не станет. Пробелы и регистр букв при сравнении не учитываются. Номер «По факту» конкретную машину не опознаёт, таких строк во вложении может быть несколько, а одно лицо в разных вложениях допустимо: у вложений свои сроки и места прохода.

6.1. Файловый архив бланков

Сформированные бланки система выкладывает на диск, чтобы заявка существовала не только внутри программы: папку архива можно отдать в сетевой доступ на чтение, и бумажная копия заявки открывается двойным щелчком без входа в систему.

Раскладка задаётся отдельно шаблоном каталогов и отдельно шаблоном имени файла. В них подставляются сведения заявки, поэтому папки складываются в понятную человеку структуру, а не в список номеров. Настраивают раскладку не через интерфейс, а командой на сервере: шаблон определяет, где физически лежат документы со сведениями работников, и его смена переносит дерево заявок целиком, поэтому право на такое изменение отделено от работы в системе и требует доступа к серверу. Команда показывает получающийся путь на примере действующей заявки до

сохранения и отклоняет неизвестное обозначение, а само изменение записывает в журнал изменений.

Изначально путь состоит из четырёх уровней - год, месяц, день и папка заявки, в имени которой стоят дата, номер и организация. Имя файла образуют вид вложения и организация. День берётся по местному времени, а не по времени хранения в базе, поэтому вечерняя заявка не уезжает в папку следующих суток. Символы, недопустимые в именах файлов Windows, заменяются читаемыми, а слишком длинное имя папки укорачивается: путь ограничен так, чтобы файл открывался с рабочего места по сети двойным щелчком.

Рядом с бланками кладётся машиночитаемый слепок заявки: поля заявки, все люди, машины и материальные ценности по вложениям, согласования и места разгрузки одним файлом. Он нужен, чтобы сведения заявки можно было передать в другую систему учёта, не разбирая печатную форму.

Туда же уезжают файлы, приложенные к заявке при подаче. Они складываются в отдельную папку внутри папки заявки: имена этих файлов задаёт заявитель, и совпадение с именем бланка перезаписало бы печатную форму. Отдельного срока хранения у них нет - файлы появляются в архиве вместе с заявкой и живут там столько же, сколько она.

И в бланке, и в слепке сведения документов записаны открытым текстом: иначе файл не открылся бы вне системы, ради чего архив и заводится. Поэтому каталог архива - хранилище персональных данных того же класса, что и база, и требования к доступу к нему те же. Подробнее в подразделе 13.6.

Выгружаются бланки тех типов вложений, у которых включено автосохранение. Тумблер стоит в карточке типа вложения и недоступен, пока архив выключен целиком или у типа нет действующего бланка.

Файлы обновляются вслед за заявкой: бланк переписывается при подаче, при изменении и по отдельной команде повторной выгрузки.

Изменилось ли содержимое, система определяет по контрольной сумме: при совпадении файл не открывается вовсе, поэтому его дата и время остаются прежними и средство синхронизации на рабочий компьютер не переносит его заново. Исправление организации переносит папку целиком, а не заводит рядом вторую.

Запись идёт не в момент нажатия кнопки, а фоновой очередью: изменение заявки ставит её в очередь и будит обработчик, тот пишет файлы отдельно от работы пользователя. Заявка, для которой запись сорвалась по временной причине, откладывается и повторяется позже. Раз в сутки ночью система сверяет свой реестр выгруженных файлов с тем, что действительно лежит на диске, и дописывает пропавшее: так восстанавливаются заявки, чья очередь потерялась вместе с перезапуском сервера. Сверка идёт по недавним заявкам, глубина окна задаётся настройкой; для более ранних предусмотрена выгрузка задним числом за указанный период. Недописанные при сбое файлы убираются, частично записанный бланк на диске не остаётся.

Файлы закрытой заявки со временем замораживаются: дальнейшие правки в системе их уже не касаются. Отсчёт идёт от того момента, когда заявка перестала действовать: у отозванной - от отзыва, у остальных - от последнего дня, на который выписаны её вложения. Срок задаётся настройкой на сервере, изначально месяц. Смысл в том, что пока заявку могут поправить задним числом, файл обязан следовать за ней, а после - становится документом и больше не меняется.

Занятое место ограничивается двумя порогами. При заполнении сверх заданной доли раздела ответственным за архив уходит предупреждение - один раз на переход через край, а не потоком. Когда свободного места остаётся меньше заданного запаса или архив упёрся в отведённый ему объём, запись останавливается и возобновляется сама, как только место появится. Заявки при этом продолжают приниматься: архив не должен доедать место, нужное самой системе.

Состояние архива видно в отдельном разделе администрирования, и разложено оно так, чтобы отвечать на вопросы дежурного, а не пересказывать устройство хранилища. Обзор показывает занятое место, отдельно число заявок, бланков и машиночитаемых описаний, свободное место на разделе с разбивкой по тому, чем оно занято, момент последней записи, число ошибок и число вложений, оставшихся без шаблона. Ниже архив разложен по месяцам и по типам вложений - видно, что занимает место. Полоса занятости подписывает каждую долю раздела при наведении. Соседняя лента перечисляет записи реестра целиком, с отбором по состоянию и счётчиком очереди: по ней видно и то, что уже записано, и то, что ждёт разбора, а сорвавшимся строкам подписан срок следующей попытки. Там же приведены действующие настройки - раскладка, пороги места и срок заморозки, - и приведены словами, с примером получающегося пути и пояснением, что произойдёт при достижении каждого порога; изменить их из интерфейса нельзя. Отсюда же исправляют ошибки записи и запускают выгрузку задним числом: за выбранный период или для бланков одного типа, когда его шаблон поправили и печатные формы нужно пересобрать.

Каждому бланку отвечает состояние выгрузки: ждёт очереди, записан, сорвался по временной причине, остался без шаблона, остановлен нехваткой места, потерял вложение. Различаются они не для порядка: временный отказ система повторяет сама, а отсутствие шаблона или места ждёт человека, и в карточке заявки работник видит это состояние рядом с вложением, не заходя в раздел администрирования. Разбор состояний приведён в руководстве по развёртыванию и сопровождению, подраздел 9.6.

Забрать сохранённое можно и не открывая сетевую папку. Из раздела администрирования выгружается всё за выбранный период одним архивом: до запуска система сообщает, сколько это файлов и какого объёма, и отказывает, когда объём выходит за отведённый предел - тогда период сужают. Архив собирается на лету и отдаётся потоком, на диске сервера он

не накапливается. Отдельные файлы забирают из карточки заявки: сохранённый бланк вложения скачивается по одному, а все файлы заявки выдаются архивом. Круг допущенных здесь тот же, что при скачивании бланка: участник заявки получает все её файлы, работник поста - только по тем вложениям, которые ему и так видны. Каждое такое обращение попадает в журнал обращений к персональным данным, см. подраздел 13.7.

Доступ разграничен тремя отдельными правами: увидеть занятое место и перечень файлов может один круг работников, запускать повторную выгрузку и донаполнение - другой, выносить файлы из системы - третий. Раскладка и пороги в этот перечень не входят: они задаются на сервере, и веб-доступ их не меняет ни при каких правах.

6.2. Уведомления

Уведомления собраны в перечне под значком в верхней панели и продублированы в личном кабинете. Приходят они без обновления страницы, а если связь с сервером прервалась - подтягиваются опросом, поэтому пропустить событие из-за разрыва нельзя.

События разложены по пяти направлениям. Заявки: подача, требование согласования, новая заявка, ждущая принятия в работу, передача для просмотра, смена статуса, вопрос и ответ по заявке, ход дополнения, напоминание молчащему согласующему. Сроки и проходы: срок действия пропуска подходит к концу, заявитель отозвал заявку, по заявке отмечен первый проход. Учётная запись: смена пароля, блокировка и разблокировка записи, блокировка входа после неудачных попыток. Новости и обращения: публикация новости и документа, новое обращение обратной связи и ответ по нему. Система: плановые технические работы, восстановление записи из корзины, заполнение файлового архива.

Поданную заявку ждёт в Центре не только согласующий, но и работник бюро, который берёт её в работу, - ему уходит отдельное извещение. Оно называет номер заявки, организацию и приславшего работника, показывает

начало сообщения и перечисляет приложенные файлы по именам: по одному номеру понять, чья заявка и насколько она срочная, нельзя, а по организации и названию накладной - можно.

Набор настраивается работником под себя: в настройках уведомлений направления раскрываются в отдельные события, и ненужное выключается целым направлением или по одному. Уведомления об учётной записи выключить нельзя - о блокировке собственной записи работник должен узнать в любом случае, и это прямо сказано на экране настроек.

Повторы одного события не заваливают перечень: несколько ответов на один вопрос или несколько передач одной заявки собираются в одну запись со счётчиком, и она поднимается наверх по последнему событию. Разделены только события разных заявок и разных обсуждений. Напоминания согласующим в такую сборку не попадают: у них свой срок повтора, и каждое должно быть заметно отдельно.

Уведомление приходит и тогда, когда сайт закрыт. Работник один раз разрешает браузеру показывать сообщения, и дальше система доставляет их на компьютер или телефон системным уведомлением: о заявке, ждущей согласования, о решении по своей заявке, об истекающем сроке пропуска. Выключенный телефон получит накопленное при включении. На компьютере уведомления доходят, пока запущен браузер: их принимает он сам, и полностью закрытый браузер получит накопленное при следующем запуске. На телефоне доставку держит операционная система, поэтому там сообщение приходит независимо от того, открыт браузер или нет; о разнице сказано прямо на экране настроек. Что именно приходит таким образом, задаёт тот же экран настроек: выключенное там не придёт ни в перечень, ни на устройство - отдельного набора для внешней доставки нет намеренно, иначе две настройки об одном и том же разошлись бы.

Разрешение даётся браузеру, а не входу в систему, поэтому уведомления продолжают приходить и после того, как учётная запись вышла по сроку; нажатие на такое уведомление приводит к форме входа, а после неё

- сразу к нужной заявке. Выход из системы вручную отключает доставку на этом устройстве: на общем компьютере следующий работник не должен видеть чужих заголовков.

На устройствах Apple (iPhone и iPad) браузер отдаёт такие уведомления только приложению, добавленному на экран «Домой»: в обычной вкладке они не приходят вовсе. Установить такое приложение умеет только Safari - остальные браузеры на этих устройствах работают на его движке и этой возможности лишены, поэтому инструкция на экране настроек выбирается по браузеру: открывшему сайт в стороннем браузере система сначала предлагает перенести адрес в Safari и даёт его скопировать. Менять привычный браузер при этом не требуется: Safari нужен один раз, для установки, дальше приложение открывается со своей иконки. Это ограничение платформы, а не системы. На остальных устройствах ничего добавлять не нужно.

Настройки доставки вне системы требуют ключей, задаваемых при установке (приложение Б руководства по развёртыванию). Пока их нет, раздел честно сообщает, что доставка не настроена, а перечень уведомлений внутри системы работает как обычно.

Запись открывается в отдельном окне с полным текстом и подробностями: номер заявки, организация и работник, приславший её, кто передал, сколько дней ждёт решения, номер дополнения. Оттуда же заявка открывается одной кнопкой, уведомление возвращается в непрочитанные или удаляется. Перечень подгружается по мере прокрутки, отбирается по признаку прочтения, разделён по дням и позволяет отметить прочитанным всё разом.

6.3. Массовый ввод участников из бланка

На мероприятие подадут списками в сотни и тысячи человек, а форма подачи рассчитана на ввод по одному. Поэтому список принимается файлом: заявитель скачивает из формы пустой бланк, заполняет его привычным

образом и загружает обратно, а система разбирает строки и наполняет ими список участников заявки. Далее заявка подаётся обычным порядком.

Бланк тот же самый, которым система печатает заявку. Отдельного формата для загрузки нет намеренно: чтобы отдать список, не нужно ни искать образец, ни сопоставлять столбцы вручную - система читает файл по той же разметке шаблона, по которой его заполняет. При выдаче в файл вписывается отметка о том, для какого вида пропуска он выдан; она хранится в свойствах документа и продублирована в скрытом листе, поэтому переживает пересохранение в редакторе.

Возможность закрыта отдельным правом, и по умолчанию его нет ни у кого, кроме администраторов. Причина не в нагрузке на сервер: заявитель, который может заполнить форму, должен заполнять форму, а файлом подаются те, у кого список действительно велик. Право открывает и загрузку, и скачивание пустого бланка сразу: иначе человек скачал бы бланк, заполнил его и получил отказ уже при загрузке.

Негодный файл отклоняется целиком, до разбора строк, и каждый отказ объясняется словами и подсказкой, что делать. Проверяются размер и внутренняя подпись файла, а не его расширение; затем отметка вида пропуска - бланк другого вида пропуска называется прямо, с указанием, для какого он выдан и какой подаётся; при отсутствии отметки сверяются подписи столбцов, и сдвинутая разметка означает предложение скачать бланк заново. Пустой список и превышение потолка в две тысячи строк на файл тоже останавливают разбор: длинный список разбивается на несколько заявок.

Строки внутри годного файла проверяются теми же правилами, что и ручной ввод, и это требование к системе, а не следствие устройства: загрузка файлом не должна быть способом обойти проверку. Обязательность полей берётся из настроек того же вложения, патент требуется по признаку гражданства и по настройке поля, гражданство сопоставляется со справочником, длины полей сверяются с тем, что примет база. Написание

имён приводится к единому виду: латинские буквы, набранные вместо русских, заменяются с показом исправленного варианта, а слитно записанное имя разбирается на фамилию, имя и отчество и помечается как требующее проверки. Совпадение с чёрным списком останавливает строку, повторы внутри файла и повторы того, что уже добавлено в заявку, отсеиваются по тем же правилам, по которым система не принимает одного человека дважды при ручном вводе.

Разбор не обрывается на первой негодной строке: чистые строки принимаются, проблемные показываются перечнем с номером строки в файле и причиной отказа, чтобы человек нашёл её у себя. Причину система формулирует сама, целиком, на русском языке. Правка возможна прямо в перечне для тех причин, которые в нём и видны: незаполненное имя, неопознанное гражданство, слишком длинное значение. Совпадение с чёрным списком и повтор так не исправляются, а сведения документов в перечне не показываются вовсе, поэтому и правятся такие строки только через обычную форму.

Места прохода, места разгрузки и таблицы проезда в файле не передаются: их задаёт заявитель на сайте сразу для всего загруженного списка, и без этого выбора список в заявку не добавляется. Перечень проблемных строк выгружается в электронную таблицу с теми же причинами, чтобы список можно было исправить в привычном редакторе и загрузить заново.

7. Поиск и работа с накопленными данными

7.1. Поиск, устойчивый к способу ввода

Поиск рассчитан на быстрый и неаккуратный ввод. По введённой строке система строит несколько вариантов запроса и ищет по каждому.

Таблица 7.1 — Что распознаёт поиск

Ситуация	Пример ввода	Что будет найдено
Часть слова, в том числе из середины	иван	Иванов, Иваненко, Селиванов
Ввод в неверной раскладке клавиатуры	bdfyjd	Иванов
Различие в регистре	ИВАНОВ	Иванов
Номер слитно и отдельно	a123вс и а 123 вс	A123BC
Опечатка в фамилии	Ивонов	Иванов

Поиск работает по фамилиям, именам и отчествам, номерам заявок, государственным регистрационным знакам, маркам транспорта, наименованиям организаций и мест разгрузки, наименованиям работ, тексту сопроводительных писем и комментариев.

Сквозной поиск проходит по заявкам, людям, транспорту, учётным записям работников, чёрным спискам, справочникам (организации, компании, места разгрузки, таблицы постов, марки, гражданства, форматы номеров), а также по новостям, объявлениям, документам и обращениям обратной связи. Каждый раздел выдачи закрыт тем же правом, что и его страница: работник видит в подсказках только то, что ему и так доступно.

Опечатки распознаются при поиске по фамилиям внутри раздела - в центре заявок и реестрах: сравнение ведётся по близости написания, поэтому «Ивонов» найдёт Иванова. Для остальных полей поиск идёт по фрагменту строки, и опечатка в середине слова результата не даст.

Сквозной поиск опечатки распознаёт тоже: раньше он требовал точного вхождения, и один и тот же запрос в центре заявок срабатывал, а в строке сквозного поиска нет. Сравнение ведётся по той же близости написания и по тому же порогу, что и в центре заявок. Слова короче четырёх символов сравниваются только точно: на трёх символах похожим оказывается почти любое слово. Государственные знаки сравниваются с допуском тоже, но близкие по написанию номера принадлежат разным машинам, и результат стоит сверять глазами. Неверную раскладку клавиатуры и номер, набранный слитно или отдельно, сквозной поиск понимает.

Списки справочников и таблиц, которые фильтруются прямо в браузере, дополнительно распознают латинское написание русского слова: `ivanov` найдёт Иванова. При поиске заявок такое написание не распознаётся.

7.2. Приведение сведений к единому виду

Часть сведений приводится к единой форме автоматически, чтобы одинаковые по смыслу записи не расходились в написании.

- Государственные регистрационные знаки: убираются пробелы и разделители, латинские буквы, внешне совпадающие с русскими, заменяются на русские, ноль и буква «О» приводятся к одному виду.
- Фамилии, имена и отчества: убираются лишние пробелы, приводится регистр, «е» и «ё» считаются одной буквой.
- Наименования организаций: приводится к единому виду организационно-правовая форма и кавычки. Применяется при разборе организаций, поступающих с заявками, и при модерации справочника.

Приведённая форма используется при сверке с чёрными списками и хранится рядом с исходной, поэтому исходное написание не теряется.

7.3. Повторное использование ранее заведённых сведений

Сотрудники и транспортные средства, ранее заводившиеся в системе, хранятся в реестрах. При оформлении заявки их не требуется вводить заново: в форме предусмотрен выбор из реестра.

По кнопке открывается окно со списком ранее заведённых записей, в котором есть собственный поиск и возможность отметить сразу несколько записей. Отмеченные записи добавляются в заявку вместе с ранее указанными сведениями.

7.4. Скорость поиска при накоплении данных

Для полей, по которым ведётся поиск, создано 38 специальных индексов. Они позволяют искать по фрагменту слова, не перебирая таблицу целиком, поэтому скорость поиска не падает по мере накопления данных.

8. Обучение работе с системой

Система рассчитана на работников без специальной подготовки, поэтому обучение встроено в интерфейс.

8.1. Обучающие туры

Обучение встроено в интерфейс: система подсвечивает элементы и объясняет их назначение прямо на рабочем экране, не отсылая к отдельному пособию.

Туров пять, по кругу задач работника: заявитель, работник поста, согласующий, принимающий и администратор. Набор доступных туров система определяет по правам учётной записи, а не по её типу: один и тот же человек нередко и принимает заявки, и ведёт справочники, поэтому ему доступны оба тура. Работник видит в меню обучения только то, что относится к его работе.

При первом входе запускается ровно один тур - профильный для этой учётной записи. Остальные доступные работник запускает сам, кнопкой «Обучение» на странице «Обзор и новости»: она открывает список туров с пометкой о том, какие уже пройдены.

Внутри тура работник не привязан к порядку: счётчик шагов открывает список всех шагов по разделам, и с него можно перейти к нужному месту, в том числе на другую страницу.

Прохождение считается отдельно по каждому туру. Работник, прошедший обучение заявителя, не теряет эту отметку, когда его назначают согласующим, и получает новый тур, а не повтор старого.

Тур можно пройти повторно в любой момент. Администратор может снять отметку о прохождении конкретному работнику - как по отдельному туру, так и по всем сразу, например при переводе на другую должность.

Туры версионироваться независимо. После существенного изменения интерфейса работникам показывается обновлённый тур той области, которая изменилась; пройденные туры остальных областей это не затрагивает.

Тур не мешает работе: он пропускает шаги про разделы, которых у работника нет по правам, и переживает отсутствие данных на экране. Там, где показывать нечего - например, у нового работника ещё нет ни одной заявки, - тур показывает пример на снимке экрана и продолжается дальше.

8.2. Встроенное руководство

Руководство дополняет туры, а не повторяет их: тур - короткий обзор основ на живом экране, руководство - справочный материал с подробностями. В системе есть раздел справки с отдельными материалами для заявителя, охранника и администратора. Материал раздела состоит из вводного текста, перечня пунктов и прикрепленного файла. Всё это ведётся администратором в самой системе, поэтому обновление справки не требует выпуска новой версии программы.

8.3. Сообщение о сбое

Если работник столкнулся с ошибкой, он может отправить сообщение прямо из системы. Сообщение сохраняется вместе со сведениями о том, что происходило в момент сбоя, и попадает в раздел обратной связи, где обрабатывается со статусами.

9. Устройство системы

9.1. Состав частей

Система собрана из отдельных частей, каждая работает в собственном контейнере. Наружу открыта одна из них, обратный прокси. Остальные работают во внутренней сети сервера и с рабочих мест недоступны.

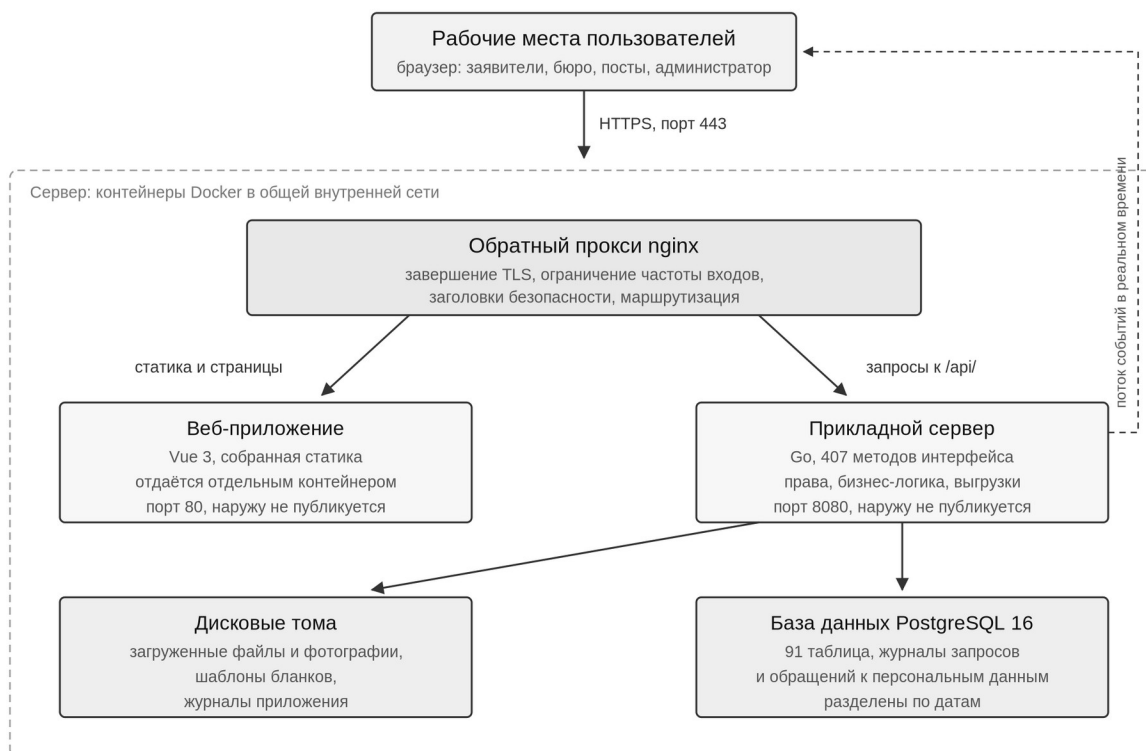


Рисунок 9.1 — Состав системы и потоки данных

Обратный прокси принимает защищённое соединение, расшифровывает его и распределяет запросы: обращения к данным уходят на прикладной сервер, всё остальное отдаёт веб-приложение. Прикладной сервер обращается к базе данных и к хранилищу файлов. Обратный поток событий идёт от прикладного сервера прямо в браузер и обновляет открытые страницы.

Таблица 9.1 — Части системы

Часть	Основа	Роль
Обратный прокси	nginx	Защищённое соединение, ограничение частоты попыток входа, заголовки безопасности, распределение запросов

Часть	Основа	Роль
Веб-приложение	Vue 3	Интерфейс, с которым работает пользователь в браузере
Прикладной сервер	Go	Проверка прав, обработка заявок, работа с данными, формирование выгрузок
База данных	PostgreSQL 16	Хранение всех сведений системы

9.2. Технологическая основа

Таблица 9.2 — Применённые технологии

Уровень	Технологии
Прикладной сервер	Go 1.26, веб-каркас Echo, работа с базой через GORM и драйвер pgx, формирование электронных таблиц и печатных форм
Веб-приложение	Vue 3.5, хранилище состояния Pinia, сборка Vite, построение диаграмм, редактор форматированного текста
Хранение	PostgreSQL 16 с разделением журнальных таблиц по датам и поиском по фрагментам слов
Развёртывание	Docker и Docker Compose, работа от непривилегированного пользователя

9.3. Фоновые задачи

Прикладной сервер сам выполняет периодические задачи, отдельный планировщик в операционной системе не нужен.

Таблица 9.3 — Периодические задачи

Задача	Периодичность	Действие
Архивация просроченных вложений	15 минут	Вложения с истёкшим сроком перестают действовать
Архивация журнала отказов	Сутки	Записи старше 90 суток переносятся в архив
Суточный снимок и сброс	Ежесуточно в 06:00	Сохраняется состояние таблиц постов, территориальные статусы обнуляются
Суточный отчёт по проходам	Ежесуточно в 21:30	Сохраняются итоги проходов и проездов за сутки
Фиксация пика посещаемости	Минута	Записывается наибольшее число одновременно работающих за сутки
Напоминания согласующим	Час	Согласующему, чьё решение ждут дольше заданного срока, отправляется уведомление
Предупреждение об истечении пропуска	Ежесуточно в 09:00	Заявителю дважды сообщается о приближении общего срока заявки - за три дня и накануне; общим сроком считается самая поздняя дата среди её активных вложений
Пересчёт показателей аналитики	60 секунд	Панель открывается сразу, без ожидания расчёта

Задача	Периодичность	Действие
Обслуживание журнальных таблиц	Сутки	Создание разделов вперёд, свёртка и удаление устаревших
Уборка технического мусора	Сутки	Удаляются недействительные маркеры продления, прочитанные и давние непрочитанные уведомления, подписки устройств без доставки
Уборка неотправленных файлов заявок	Час	Удаляются файлы, загруженные к заявке, которую так и не отправили, и файлы, потерявшие запись в базе
Проверка сроков действия паролей	Ежесуточно в 04:00	Работникам, у которых срок действия пароля вышел, поднимается требование сменить пароль при следующем входе; тем, у кого срок подходит, заранее уходит предупреждение. Паролей задача не меняет и писем с паролями не рассылает. При выключенном сроке действия задача не делает ничего
Разбор очереди писем	15 секунд	Накопившиеся письма передаются почтовому серверу, непринятые повторяются с нарастающей паузой. Задача не запускается, если почта не настроена
Выгрузка бланков в файловый архив	15 секунд и сразу при изменении заявки	Разбирается очередь записи файлов на диск
Повтор неудавшихся выгрузок	5 минут	Заявки, чья запись сорвалась по временной причине, выгружаются заново
Сверка файлового архива с диском	Ежесуточно в 03:00	Реестр выгруженных файлов сверяется с содержимым каталога, пропавшее дописывается
Уборка недописанных файлов архива	Час	Удаляются временные файлы, оставшиеся после прерванной записи

ПРИМЕЧАНИЕ. Резервное копирование в этот перечень не входит. Его выполняет не прикладной сервер, а отдельный сценарий, который ставится на расписание средствами операционной системы при установке системы: ежесуточное копирование и ежемесячная проверка восстановимости копии. Порядок описан в руководстве по развёртыванию и сопровождению.

10. Организация данных

10.1. Состав базы данных

База содержит 101 таблица: справочники, учётные записи и права, заявки со связанными сущностями, реестры людей и транспорта, таблицы постов, журналы.

Дополнения заявки хранятся отдельно от неё самой: одна таблица описывает саму добавку (номер по счёту в заявке, состояние, автор, пояснение и итоговое решение), вторая - голоса согласующих по ней. Состав голосующих записывается в момент подачи добавки и дальше не меняется вслед за заявкой, поэтому решение видно тем же составом, каким оно принималось. Круг согласования добавки отделён от круга самой заявки намеренно: голоса по заявке при этом остаются нетронутыми, а от них зависит допуск на посты уже выданных пропусков.

Строки вложений - люди, транспорт и ценности - хранят признак того, какой добавкой они заведены. У поданных вместе с заявкой он пуст. По этому признаку и определяется, допущена ли строка на посты. Поданные с заявкой и добавленные в её собственный круг согласования допущены наравне: их судьбу решает сама заявка. Строка отдельной добавки допускается её принятием, а до него и при отрицательном решении на посты не выходит. Одно и то же условие применяется и при выдаче состава охране, и при формировании бланка, и при отчётах, поэтому расхождения между тем, что напечатано в бланке, и тем, что видит работник поста, не возникает.

Файлы, приложенные к заявке, лежат на диске сервера, а в базе хранятся только сведения о них: имя, тип, размер, кто загрузил. Прикрепить файл можно лишь в момент подачи, поэтому загрузка идёт до создания заявки: файл ложится на диск и ждёт, пока подача свяжет его с заявкой. Файл, о котором подача так и не сказала, система убирает сама через сутки - заявитель выбрал документы и закрыл форму, не отправив её. Той же уборкой снимаются файлы, потерявшие запись в базе.

Приложенный файл хранится ровно столько, сколько сама заявка: отдельного срока у него нет, и командой очистки он не удаляется. Заявки не удаляются автоматически, поэтому и файлы остаются доступными всё время, пока доступна заявка. Удаление заявки снимает сведения о её файлах вместе с ней, а сами файлы убирает с диска та же почасовая уборка.

Две журнальные таблицы растут быстрее прочих, поэтому физически разделены по датам. Это позволяет удалять устаревшие сведения мгновенно, отбрасывая целый раздел, вместо построчного удаления, которое на больших объёмах занимало бы часы.

Таблица 10.1 — Разделение журнальных таблиц

Журнал	Разделение	Срок хранения
Журнал запросов	По суткам	Подробные записи 30 суток, далее суточные итоги
Журнал обращений к персональным данным	По месяцам	36 месяцев без свёртки

Остальные служебные записи хранятся построчно. Те из них, что обесцениваются сами, суточная задача удаляет без участия человека: это недействительные маркеры продления сеанса и уведомления, у прочитанных и непрочитанных свои сроки, и задаются они параметрами установки.

История действий над сущностями, суточные слепки таблиц постов и суточные итоги журнала запросов не удаляются автоматически. Они нужны для корзины, отчётов и разбора спорных случаев, поэтому решение об их удалении принимает подразделение ИТ отдельной командой; порядок описан в руководстве по развёртыванию и сопровождению. При потоке в 50-200 заявок в сутки база прирастает на 2-4 ГБ в год, то есть надобности в такой очистке годами не возникает.

10.2. Сохранность исторических сведений

Записи справочников не удаляются физически, а переводятся в архив. Заявка прошлого года, ссылающаяся на упразднённое место разгрузки или снятую с учёта марку, остаётся полностью читаемой. Архивная запись не предлагается при заполнении новых заявок и помечается в старых.

Удалённые строки таблиц постов попадают в корзину, откуда их можно восстановить.

Отдельно от этого работает резервное копирование: ежедневно снимается выгрузка базы, к ней прилагаются архивы загруженных файлов, копии хранятся по схеме семь суточных, четыре недельных и шесть месячных. Раз в месяц система сама проверяет, что копия разворачивается и содержит данные. Копии шифруются, ключ хранится вне сервера. Порядок настройки и восстановления описан в руководстве по развёртыванию и сопровождению.

10.3. Поиск по большим объёмам

Для поиска по фамилиям, номерам заявок, регистрационным знакам и наименованиям организаций создано 38 специальных индексов. Они позволяют искать по фрагменту слова и с опечатками, не перебирая таблицу целиком, поэтому скорость поиска не падает по мере накопления данных.

11. Программный интерфейс

Обмен данными между браузером и сервером идёт через программный интерфейс. Он же может использоваться для интеграции с другими системами предприятия.

Зарегистрировано 511 методов в 39 группах. Ответ всегда имеет одинаковую структуру, что упрощает разбор при интеграции.

Листинг 11.1 — Структура ответа программного интерфейса

```
{
  "success": true,
  "data":    { ... },
  "meta":    { "page": 1, "limit": 20, "total": 137 },
  "error":   ""
}
```

Поле `meta` присутствует у методов, возвращающих постраничные списки: оно сообщает номер страницы, её размер и общее число записей. При ошибке поле `success` принимает значение `false`, а пояснение помещается в `error`.

Без входа в систему отвечают только семь методов: вход, продление сеанса, перечень типов работников, признак режима технических работ, контактные сведения, поток событий и выгрузка файлового архива за период. Все остальные требуют действующего маркера доступа и проходят проверку прав.

Признак режима технических работ отдаётся вместе с объявленным сообщением, сроками работ и контактами поддержки. Эти сведения публичны по назначению: их читает посетитель, которого система в этот момент не пускает внутрь.

Поток событий и выгрузка архива вынесены из-под проверки маркера по одной причине: браузер не передаёт маркер доступа ни при подключении к потоку, ни при переходе по ссылке скачивания. Вместо маркера предъявляется одноразовый билет. Выдаёт его обычный, защищённый метод - там же проверяются право на выгрузку и допустимый объём. Билет живёт минуту, гасится при первом предъявлении и хранит в себе и учётную запись заказавшего, и границы запрошенного периода, поэтому подставить в ссылку другой период нельзя. Работник в журнале обращений к персональным данным берётся из билета, то есть выгрузка не остаётся безымянной.

Отдельно устроена выдача загруженных изображений: фотографии мест разгрузки и строк таблиц постов браузер запрашивает обычным тегом изображения, который не передаёт маркер доступа, поэтому они отдаются по прямой ссылке. Ссылка при этом неугадываема: имя файла на диске заменяется случайным, и получить его можно только из ответа метода, доступ к которому разграничен.

Описание интерфейса формируется из исходного кода при сборке, поэтому не расходится с фактической реализацией.

12. Обновление данных без перезагрузки

Открытые страницы обновляются сами: новая заявка появляется в центре заявок, отметка о въезде видна другим постам, счётчик непрочитанного меняется без нажатия кнопки обновления.

Применена схема, при которой сервер сообщает только то, какую область следует обновить, но не передаёт сами сведения. Получив сигнал, браузер выполняет обычный запрос, к которому применяются права конкретного работника. Благодаря этому по каналу обновлений невозможно узнать ничего сверх собственных полномочий: он не переносит данные.

Подключение к потоку событий авторизуется одноразовым билетом, а само соединение принудительно обновляется каждые 10 минут. При обновлении повторно проверяются права и блокировка учётной записи, поэтому отзыв доступа вступает в силу не позднее чем через 10 минут даже у работника с открытой страницей.

13. Защита информации

13.1. Проверка подлинности

Таблица 13.1 — Механизмы проверки подлинности

Механизм	Реализация
Хранение паролей	Алгоритм Argon2id, устойчивый к подбору на видеокартах. Пароли в открытом виде не хранятся и не попадают в журналы
Требования к паролю	Настраиваемые минимальная длина и обязательный состав символов. Проверяются на сервере при любой установке пароля
Срок действия пароля	Настраиваемый срок, по истечении которого система требует от работника задать новый пароль и до этого никуда его не пускает
Смена пароля работником	Работник меняет свой пароль сам, подтверждая действие текущим паролем
Запрет повторного использования	Вернуться к любому из десяти последних паролей учётной записи нельзя. Правило действует на все пути смены
Пароль при заведении учётной записи	Придумывается системой и высылается работнику письмом; свой пароль работник задаёт при первом входе
Прекращение сеансов при смене пароля	Любая смена пароля аннулирует маркеры продления работника на всех устройствах
Маркер доступа	Действует 15 минут, подписан отдельным ключом

Механизм	Реализация
Продление сеанса	Отдельный маркер сроком 7 суток, передаётся только по защищённому соединению
Одноразовость продления	Использованный маркер продления сразу становится недействительным
Обнаружение кражи сеанса	Повторное предъявление уже использованного маркера аннулирует всю цепочку сеансов работника
Завершение всех сеансов	Администратор может отозвать доступ работника немедленно
Защита от подбора	Блокировка учётной записи после серии неудачных попыток с нарастающим сроком и ограничение частоты попыток с одного адреса

Защита от подбора устроена так. Пять неудачных попыток за пять минут закрывают вход в учётную запись, и каждая следующая серия из пяти попыток закрывает его дольше предыдущей: сначала на минуту, затем на пять, пятнадцать, тридцать минут и на час. Час - предел, выше срок не поднимается. Отсчёт возвращается к началу после успешного входа и после суток без единой неудачной попытки; администратор может снять блокировку досрочно в карточке работника, не дожидаясь конца срока. Работник на странице входа видит, сколько осталось ждать.

Отдельно от учётной записи считаются попытки с одного сетевого адреса: те же пять неудач закрывают вход с этого адреса на минуту, и этот срок не растёт. Нарастающий срок к адресу не применяется намеренно: за одним внешним адресом работает целый отдел, и ошибки одного работника не должны запирают остальных.

Несуществующий логин закрывается на те же сроки и тем же сообщением, что и настоящий. Это сделано намеренно: если бы выдуманное имя всегда запиралось на минуту, а настоящее уходило на пять и пятнадцать, по длительности блокировки можно было бы выяснять, какие учётные записи в системе есть.

Сбой самой системы в счёт неудачных попыток не идёт. Если вход не удался не из-за пароля, а из-за того, что база данных недоступна, исчерпан пул соединений или запрос не уложился в срок, система отвечает отдельным сообщением - **«Вход временно недоступен из-за ошибки на сервере.**

Повторите попытку позже.» - и лестницу блокировки не двигает. Иначе после аварии работники оказались бы заперты за то, чего не делали. Причина такой неудачи записывается и в журнал событий, и в системный журнал: журнал событий живёт в той же базе и при полной аварии не сохранится, а системный её переживает.

Обнаружение кражи сеанса работает так: если маркер продления похищен и использован посторонним, законный работник при следующем продлении предъявит уже использованный маркер. Система расценит это как признак компрометации и прекратит оба сеанса, а событие останется в журнале.

Требования к паролю задаются в разделе «Настройки», вкладка «Безопасность», и действуют на любую установку пароля: при заведении учётной записи, при смене работником, при смене администратором и при обновлении паролей всем работникам. Настраиваются минимальная длина - от 6 до 128 символов, по умолчанию 8 - и обязательное присутствие буквы, заглавной буквы, строчной буквы, цифры и специального знака по отдельности; из поставки включены требование буквы и требование цифры. Проверка выполняется на сервере, поэтому обойти её обращением к системе мимо интерфейса нельзя.

Срок действия пароля настраивается там же и в поставке выключен: включать его должен человек осознанно. При включённом сроке система ежедневно в 04:00 отбирает работников, чей пароль старше заданного числа суток, и каждому из них поднимает требование сменить пароль. Сам пароль при этом не меняется и никуда не отправляется: работник входит своим прежним паролем, а дальше формы смены пароля система его не пускает. Срок задаётся в пределах от 30 до 120 суток, по умолчанию 90. Верхняя граница взята из приказа ФСТЭК России N 21, который для информационных систем персональных данных требует смены пароля не реже чем раз в 120 суток. За заданное число суток до истечения - от 0 до 30, по умолчанию 7, ноль означает не предупреждать - работник получает

письмо и уведомление о том, что срок подходит; сменив пароль сам, он начинает отсчёт заново, и требовать смены системе будет уже нечего.

Так пароль работника при обновлении по сроку нигде не появляется в открытом виде: он остаётся известен только своему владельцу и хранится в системе единственным способом - вычислением Argon2id. Почтовая рассылка нужна здесь лишь для предупреждения о скором истечении; сама проверка сроков без неё работает, а работник, у которого адрес не указан, узнаёт об истечении на входе. Заблокированных работников и учётные записи, перенесённые в архив, проверка не касается вовсе: входить им и без того некуда.

Пароль, придуманный самой системой, появляется при трёх действиях администратора: заведении учётной записи, обновлении паролей всем работникам и смене пароля из карточки работника. Такой пароль не короче 12 символов, взят из криптографического источника случайности и заведомо удовлетворяет действующим требованиям. Визуально неоднозначные знаки из набора исключены - такой пароль переписывают из письма руками, и путаница единицы со строчной латинской L стоит обращения в бюро пропусков.

При заведении учётной записи поле пароля можно оставить пустым, и тогда пароль придумывает система, а тот, кто заводит запись, его не видит. Пустое поле допустимо только при указанном адресе почты и настроенной рассылке: пароль, который негде прочесть, запирает работника снаружи, поэтому в остальных случаях система отказывает и просит задать пароль вручную. Заданный вручную пароль остаётся способом завести учётную запись человеку без адреса почты. Требование задать свой пароль при первом входе поднимается в обоих случаях: и придуманный системой, и заданный администратором пароль прошёл через чужие руки.

Работнику он уходит письмом открытым текстом. Это осознанный размен: другого канала связи с работником у системы нет, и доставить придуманный за него пароль иначе нечем. Оба действия исключительные -

раздача паролей при вводе системы в эксплуатацию, подозрение на утечку, потерянный работником пароль, - и повседневное обновление по сроку на них не опирается. Риск дополнительно ограничен сроком жизни такого пароля: при включённом требовании сменить пароль при первом входе - включено по умолчанию - присланный пароль годится ровно на один вход. Пока работник не задаст свой, система отвечает отказом на любое обращение, кроме тех, без которых не открылись бы сама форма смены пароля и выход из системы. Заданный работником пароль отменяет присланный, и лежащее в почтовом ящике письмо перестаёт что-либо открывать.

Тот же запрет держит и работника, у которого истёк срок действия пароля, - с той разницей, что открытого пароля в этом случае нет нигде. Требование в обоих случаях проверяется по состоянию учётной записи в базе данных, а не по выданному ранее маркеру доступа: оно вступает в силу не позже чем через 30 секунд и не ждёт, пока истечёт уже выданный маркер.

Смена пароля - работником или администратором - аннулирует все маркеры продления сеанса этого работника: продолжить работу на других устройствах и в ранее открытых вкладках нельзя, требуется войти заново. Требование сменить пароль по истечении срока сеансы не обрывает, и обрывать их незачем: проверка стоит на каждом обращении к серверу, поэтому уже открытая вкладка упирается в форму смены на первом же действии, а после смены пароля прежние маркеры отзовутся сами. И смена пароля, и отметка об истечении срока попадают в журнал изменений учётной записи - там же, где видны её блокировки и правки. Сам пароль ни в открытом виде, ни в составе письма в журналы не попадает.

Вернуться к прежнему паролю система не даёт: десять последних паролей учётной записи запоминаются, и попытка задать любой из них отклоняется. Правило одинаково для всех путей смены - работник меняет пароль сам, администратор задаёт его из карточки, система обновляет пароли всем - и распространяется на пароль, придуманный самой системой: иначе

работник, получив письмо, задал бы себе пароль из этого же письма. Первый пароль запоминается вместе с заведением учётной записи. Хранятся, как и действующий пароль, только вычисления Argon2id, поэтому сравнение с перечнем означает вычисление хеша заново на каждую запись - отсюда и глубина в десять, а не «все за всю историю»: проверка обязана укладываться в доли секунды, а не в секунды. Перечень наружу не отдаётся ни одним методом, в истории учётной записи и выгрузках не показывается, записи глубже десятой удаляются при очередной смене, а вместе с учётной записью исчезает целиком.

Свой пароль работник меняет сам: в личном кабинете кнопка «Сменить пароль», текущий пароль требуется подтвердить. Подтверждение нужно потому, что перехваченный чужой сеанс без него давал бы смену пароля, то есть полный захват учётной записи. Отдельно администратор может сменить пароль одному работнику с отправкой письмом - это замена прежнего порядка, при котором пароль придумывали руками и диктовали по телефону, то есть он проходил через третьи уши.

Работников, у которых не указан адрес почты, обходят стороной только действия, высылающие придуманный пароль: сменить пароль и не доставить его - значит запереть человека снаружи. Их перечень система показывает администратору до обновления паролей всем работникам и называет в отчёте по каждому такому прогону. На требование сменить пароль по истечении срока отсутствие адреса не влияет.

13.2. Разграничение доступа

Модель прав описана в подразделе 4.2. С точки зрения защиты информации существенны три её свойства.

Проверка выполняется на сервере при каждом обращении. Скрытие кнопки или пункта меню в интерфейсе рассматривается как удобство, а не как мера защиты: работник, обратившийся к системе в обход интерфейса, получит отказ на общих основаниях.

Права вычисляются по принципу «запрещено всё, что не разрешено». Отсутствие явного разрешения означает отказ.

Каждый отказ фиксируется в журнале с указанием работника, запрошенного действия и времени.

13.3. Вход от имени другого работника

Работник сообщает, что раздел не открывается, список пуст или кнопка не работает, - а на своём экране администратор ничего подобного не видит: у них разные права, разные организации и разный состав данных. Прежде такую задачу решали единственным доступным способом: администратор узнавал у работника пароль и входил под ним. Порядок этот плох дважды. Пароль перестаёт быть известным только владельцу, тогда как меры защиты по приказу ФСТЭК России N 21 исходят из обратного - аутентификатор знает лишь тот, кому он выдан. И журнал перестаёт отвечать на вопрос «кто это сделал»: всё, что администратор сделает под чужой учётной записью, записывается на работника, и отделить одно от другого нечем.

Поэтому в системе есть отдельный режим работы от чужого имени. Администратор открывает систему глазами работника, не зная и не меняя его пароля, а журнал сохраняет, что за этими действиями стоял администратор.

Кому доступен. Режим закрыт правом «Вход от имени пользователя». Одного права мало: сервер дополнительно сверяет полномочия сторон и отказывает, если у выбранного работника есть право, которого нет у самого администратора. От имени супер-администратора не входит никто, от имени администратора - только супер-администратор. Без такой проверки режим сам стал бы способом повысить себе полномочия: достаточно выбрать более полномочного человека и действовать его правами. Не открывается режим и для учётных записей, которые не пускают собственного владельца, - отключённых, заблокированных и тех, кому назначена обязательная смена пароля.

Что в режиме запрещено. Граница проведена по судьбе учётной записи: смотреть чужими глазами можно, распоряжаться учётной записью - нельзя. Чтение не ограничено ничем, ради него режим и заведён. Изменяющие обращения сверяются с закрытым перечнем, и попытка выполнить закрытое действие получает отказ с предложением вернуться в свою учётную запись.

Таблица 13.2 — Действия, недоступные при работе от чужого имени

Что закрыто	Почему
Смена пароля - своего, чужого, рассылкой всем работникам	Свой пароль в этом режиме - пароль работника, и смена отняла бы у владельца доступ к собственной учётной записи
Изменение общесистемных настроек	Под ними срок действия паролей и прочие общие параметры; менять их из чужой учётной записи незачем
Перенос учётных записей в архив и восстановление из архива	Распоряжение судьбой учётной записи, в том числе чужой
Смена типа учётной записи, роли, признака администратора, групп прав	Через них администратор закрепил бы за собой полномочия чужими руками
Правка прав, групп прав и ролей	То же самое, но в обход карточки работника
Блокировка, разблокировка, снятие блокировки входа	Распоряжение доступом, пусть и в пользу владельца
Вход от имени третьего работника	Иначе проверка полномочий обходится в два шага
Подтверждение и отзыв согласия на обработку персональных данных	Согласие человек даёт за себя; подтверждение чужими руками согласием не является, а отзыв чужими руками отнимает у работника доступ

Срок доступа. Маркер, выданный от чужого имени, действует 30 минут и не продлевается: режим нужен на время разбора одного обращения, а забытая вкладка не должна оставаться чужой учётной записью до конца рабочего дня. По истечении срока сеанс сам возвращается в учётную запись администратора. Пока режим открыт, внизу экрана постоянно висит полоса с именем работника, остатком времени и кнопкой возврата: администратор, забывший, от чьего имени действует, - худший исход из возможных, и полоса не перекрывается ничем.

Что остаётся в журнале. Открытие и закрытие режима записываются отдельными событиями в историю той учётной записи, от чьего имени работали: кто открыл сеанс, когда и до какого времени он был действителен. Пара таких записей задаёт окно, внутри которого действия учётной записи принадлежат не её владельцу. Каждая запись, сделанная внутри окна, дополнительно несёт отметку об инициаторе режима, поэтому отличить действия администратора от действий самого работника можно и не сверяясь с границами окна. Работник в журнале администратором не подменяется намеренно: история сущности отвечает на вопрос, под какой учётной записью выполнено действие, а на вопрос, кто его затеял, отвечает отметка.

13.4. Защита передаваемых данных

Соединение защищается протоколами TLS 1.2 и 1.3, устаревшие версии и слабые алгоритмы отключены. Обращения по незащищённому протоколу перенаправляются на защищённый.

Дополнительно передаются заголовки, ограничивающие поведение браузера: обязательное использование защищённого соединения, запрет встраивания страниц системы в чужие сайты, запрет угадывания типа содержимого, ограничение источников загружаемых ресурсов, запрет доступа к камере, микрофону и определению местоположения.

13.5. Защита от типовых атак

Таблица 13.3 — Меры против типовых атак

Угроза	Мера защиты
Внедрение команд в запрос к базе данных	Все запросы к базе параметризованы. В конструкторе отчётов имена полей подставляются только из фиксированного перечня, заданного в коде, а не из введённого пользователем текста
Выполнение чужого сценария в браузере	Форматированный текст очищается перед выводом по перечню разрешённых элементов, встроенные сценарии и обработчики событий удаляются
Обращение к чужим данным по идентификатору	Принадлежность проверяется на сервере. Перечень заявок обычному работнику возвращает только его собственные
Действия в обход интерфейса	Права проверяются на сервере при каждом обращении

Угроза	Мера защиты
Загрузка вредоносного файла	Тип определяется по содержимому файла, а не по расширению, поэтому переименование не помогает. Размер ограничен, имя файла на диске заменяется на служебное
Подбор пароля	Ограничение частоты попыток и блокировка учётной записи
Избыточная нагрузка запросами	Ограничение числа запросов на работника и отдельное, более строгое, ограничение попыток входа
Обход чёрного списка подменой букв	Записи и запросы приводятся к единому виду перед сравнением, подмена русских букв латинскими не срабатывает

13.6. Защита персональных данных при хранении

Сведения документов, удостоверяющих личность, хранятся в базе в зашифрованном виде. Применён алгоритм AES-256 в режиме, который обеспечивает одновременно скрывание содержимого и защиту от подмены.

Шифрование выполняется автоматически при записи и расшифровка при чтении, поэтому записать такие сведения в открытом виде в обход шифрования нельзя.

Поиск по зашифрованным полям решён отдельно: рядом с зашифрованным значением хранится необратимая свёртка, вычисленная с секретным ключом. Поиск ведётся по ней, что позволяет находить запись, не расшифровывая всю таблицу и не раскрывая содержимое.

Тем же ключом шифруются файлы, приложенные к заявке. Поле, в которое их кладут, общее, и что именно окажется в приложенном документе, система заранее не знает, поэтому содержимое считается сведениями о людях. Хранить номер документа зашифрованным, а его снимок рядом открытым не имело бы смысла: резервная копия файлов уносила бы то, что защищено в базе. Файл записывается по частям, расшифровывается при выдаче на лету и целиком в память не читается. Признак того, что файл был обрезан, проверяется вместе с расшифровкой: без него укороченный файл открывался бы как целый.

Изображения при загрузке перекодируются и уменьшаются до предела, заданного параметром установки. Вместе с перекодированием пропадают

служебные сведения снимка - в том числе координаты места съёмки и модель устройства, которых в самом документе нет.

Файлы, которые система выкладывает в файловый архив - бланки и машиночитаемые описания заявок, - шифруются на двух получателей сразу. Первый получатель принимающая сторона: файл открывается её закрытым ключом, а на сервере бюро этого ключа нет вовсе, поэтому доступ к каталогу или к его копии документов не даёт. Второй получатель сама система: без него она не прочитала бы собственный архив и не собрала бы выгрузку по кнопке в карточке заявки. Применён тот же формат и тот же порядок обращения с ключами, что и при шифровании резервных копий.

Шифрование архива включается заданием пары ключей и по умолчанию выключено: система, отдающая архив в доверенный сегмент сети, продолжает работать как прежде. Заданный ключ принимающей стороны без ключа системы отклоняется при запуске - иначе служба записывала бы файлы, которые сама открыть не может. Файлы, записанные до включения, продолжают читаться: признак берётся из имени файла, а не из настройки.

Даже с шифрованием каталог архива защищается наравне с базой: права на чтение только у прикладного сервера и у тех, кому папка отдана в сетевой доступ, а сам каталог не может находиться внутри общедоступных каталогов системы - прикладной сервер проверяет это при запуске. Порядок описан в руководстве по развёртыванию и сопровождению.

ОПАСНО. Ключ шифрования является единственным способом прочитать эти сведения. При его утрате данные не восстанавливаются ни из резервной копии базы, ни средствами разработчика: копия содержит те же зашифрованные значения. Порядок хранения ключа описан в руководстве по развёртыванию и сопровождению.

13.7. Учёт обращений к персональным данным

Ведётся отдельный журнал обращений к сведениям о людях. Записываются работник, характер действия (просмотр, создание, изменение, удаление), затронутый раздел, сетевой адрес, время и результат.

Журнал доступен администратору в разделе администрирования системы, с фильтрами по работнику, действию и периоду. Открывается он по отдельному праву, то есть доступ к самому журналу тоже разграничен.

Записи хранятся 36 месяцев и не удаляются вместе с обычным журналом запросов. Запись выполняется в фоне и не замедляет работу пользователя, при этом сведения о запросе снимаются до передачи в фоновую задачу, что исключает их искажение.

Наравне с обращениями к карточкам людей учитывается и вынос сведений файлами. В журнал попадают выгрузка заполненного бланка, выгрузка файлового архива за период, скачивание отдельного файла архива и архива одной заявки, просмотр перечня выложенных файлов, оценка объёма выгрузки, перечень и скачивание файлов, приложенных к заявке, а также выгрузка перечня заявок за период из центра заявок. Это самый массовый вынос сведений из системы: один архив за месяц уносит бланки сотен заявок, и учитывать его поштучно важнее, чем открытие одной карточки. Выгрузка за период идёт по одноразовому билету и заголовка с маркером доступа не несёт, поэтому работник в записи определяется по билету, а не по запросу.

13.8. Согласия на обработку персональных данных

При подаче заявки заявитель подтверждает согласие на обработку персональных данных. Фиксируется факт согласия, его вид, сетевой адрес и сведения о браузере в момент подтверждения, а также время. Отзыв согласия поддерживается и также фиксируется временем.

Вместе с согласием сохраняются редакция текста и его контрольная сумма. Редакция отвечает на вопрос, какое требование выполнял работник, контрольная сумма - какой именно текст он видел: администратор может

поправить формулировку, не повышая редакцию, и без контрольной суммы подтвердить содержание принятого текста было бы нечем. Обе величины ставит сервер по текущим настройкам, из запроса они не принимаются.

Документ об обработке персональных данных публикуется администратором в системе и доступен по ссылке из формы подачи заявки. Если задан текст согласия, на этой странице показывается он - тот же текст, который работник подтверждает при входе; загруженный файл остаётся доступным для скачивания. Когда текст не задан, страница показывает сам файл.

Обязательное согласие при входе. Администратор может потребовать согласие от всех работников: в разделе «Обработка данных» включается признак и задаётся текст согласия. Пока признак выключен или текст не заполнен, требование не действует и работа идёт обычным порядком.

Текст можно набрать в редакторе или получить из загруженного документа: при загрузке файла его содержимое переносится в редактор сразу. Разбор восстанавливает абзацы, нумерованные пункты, маркированные списки и заголовки; поддерживаются форматы PDF, DOCX и XLSX, для остальных текст вводится вручную. Таблицы разбор не воспроизводит, а собственная нумерация текстового процессора в содержимое файла не входит, поэтому результат рассчитан на вычитку администратором перед сохранением.

Работник, не давший согласия, видит окно с текстом. До согласия ему доступны только само согласие, чтение опубликованного документа и выход из системы; остальные действия система отклоняет. Супер-администратор проходит всегда - иначе ошибку в настройке согласия было бы невозможно исправить через интерфейс.

Новый работник при первом входе встречает сразу два требования: согласиться с текстом и задать свой пароль взамен присланного. Порядок между ними задан - сначала согласие, затем пароль, - и пока открыто окно согласия, требование сменить пароль его не перебивает. Порядок именно

задан, а не сложился: два независимых требования, каждое из которых закрывает всё постороннее, иначе закрыли бы друг другу единственный выход, и работник не попал бы в систему вовсе.

У текста есть редакция. При сохранении изменённого текста система спрашивает администратора, запросить ли согласие заново у всех: изменённый текст - это новая редакция, и подтверждать её обычно надо заново, но правка опечатки того не стоит. По утвердительному ответу редакция повышается тем же действием, что и сохранение текста, - отдельные шаги оставляли бы промежуток, в котором работникам показывают новый текст, а достаточным считается согласие, данное прежнему. Отказ сохраняет текст, не трогая редакцию. Повысить редакцию без правки текста можно отдельной командой в том же разделе. Согласие работника считается действующим, пока его редакция не ниже требуемой.

Ход сбора виден в том же разделе: доля подтвердивших текущую редакцию и поимённый список тех, кто ещё нет, с выгрузкой в электронную таблицу. Счёт ведётся по тем работникам, кого требование реально касается: без учётной записи супер-администратора, без архивных и заблокированных. Пока требование выключено, сбор не идёт и сводка сообщает об этом, а не показывает нулевую долю.

Пока согласия нет, персональные данные работника не видят другие. Скрываются и фамилия с именем и отчеством, и рабочие контакты - почта и телефон. Вместо ФИО система показывает остальным логин учётной записи: в списках работников и заявок, в истории, вопросах, отметках прочтения, на экране поста, в справочниках, журналах, отчётах и аналитике. Логин выбран намеренно: подпись вида «данные скрыты» сделала бы несколько строк неразличимыми, и согласующего в списке было бы не выбрать. Сквозной поиск, пока данные скрыты, по почте и телефону не ищет вовсе, иначе подсказка подтверждала бы, чей это адрес.

Скрытие касается только показа. Сами данные хранятся как были, и правка карточки работника их не затирает: поля, которых нет в запросе, система не трогает.

Скрытие снимается, как только работник согласился хотя бы раз: признаком служит наличие согласия вообще, а не подтверждение текущей редакции - иначе правка текста разом обезличила бы всех, кто ещё не успел перезайти. Пока требование согласия выключено, не скрывается ничего.

Отзыв согласия. Работник отзывает своё согласие сам - в личном кабинете, отметкой согласия в верхней части страницы: она же показывает дату, когда согласие было дано. Если он обратился в бюро пропусков, отозвать согласие за него может администратор из карточки работника. В обоих случаях доступ закрывается сразу: система снова показывает окно согласия, и до нового подтверждения работать в ней нельзя - об этом предупреждает вопрос, который задаётся перед отзывом.

Выдача и отзыв попадают в историю учётной записи. В записи о выдаче сохраняется редакция текста, с которой работник согласился; в записи об отзыве видно, отозвал он согласие сам или это сделал администратор по его обращению. В разделе работников состояние согласия видно, не открывая историю: у не подтвердившего вместо фамилии стоит пометка, а в карточке - дата согласия либо отметка, что его нет.

13.9. Журналы и прослеживаемость

Таблица 13.4 — Журналы системы

Журнал	Что фиксирует	Кому доступен
Журнал запросов	Все обращения к системе: работник, действие, результат, длительность	Администратору и работникам с правом просмотра
Журнал обращений к персональным данным	Обращения к сведениям о людях	По отдельному праву
Журнал изменений	Кто, когда и что изменил в сущностях системы	Администратору
Журнал отказов в доступе	Попытки выполнить действие без прав	Администратору

Журнал	Что фиксирует	Кому доступен
Журнал входов	Входы, выходы, неудачные попытки, блокировки и их снятие администратором	Администратору

Совокупность журналов позволяет восстановить картину по любому вопросу вида «кто это сделал и когда».

ПРИМЕЧАНИЕ. Неудача входа по вине системы записывается в журнал входов без привязки к учётной записи - в этот момент система ещё не знает, кто именно пытался войти. В личной истории входов работника такие записи не показываются; их смотрят по имени учётной записи при разборе происшествия.

Адрес запроса записывается в журнал с затёртыми значениями секретных параметров: одноразовый билет, маркер доступа и ключ выгрузки сохраняются как признак «параметр был», без самого значения. Сделано это потому, что сроки жизни у секрета и у журнала несопоставимы: билет действует меньше минуты и гасится при первом предъявлении, а журнал хранится месяцами, читается через интерфейс и выгружается в электронную таблицу. Особенно это важно для файлового архива, где билет открывает выгрузку бланков с паспортными сведениями.

13.10. Автоматический контроль защищённости

Поиск уязвимостей встроен в конвейер сборки и выполняется при каждом изменении программы, а также еженедельно по расписанию, когда сама программа не менялась. Последнее важно: сведения об уязвимости часто появляются уже после выпуска версии.

Таблица 13.5 — Средства автоматического поиска уязвимостей

Средство	Что проверяет	Поведение при обнаружении
govulncheck	Библиотеки серверной части на уязвимости из базы уязвимостей Go. Учитывает, вызывается ли уязвимый код фактически, что отсеивает ложные срабатывания	Сборка прерывается
npm audit	Библиотеки интерфейса, участвующие в сборке	Сборка прерывается при уровне «высокий» и выше

Средство	Что проверяет	Поведение при обнаружении
Trivy	Собранный образ контейнера целиком: системные пакеты операционной системы и библиотеки внутри образа	Сборка прерывается при уровне «критический» и «высокий»

Прерывание сборки означает, что версия с известной уязвимостью не может быть выпущена: её невозможно собрать и выложить, пока уязвимость не устранена.

Обновления библиотек предлагаются автоматически, сгруппированные по назначению, и проходят полный набор тестов до применения. Благодаря этому зависимости не устаревают незаметно.

Дополнительно проведён аудит разграничения доступа по методике проверки функциональной авторизации: последовательно проверялось, что каждое действие недоступно работнику без соответствующего права. Выявленные несоответствия устранены. Чтобы они не появились вновь при развитии системы, добавлены автоматические проверки, закрепляющие требуемое разграничение: попытка выпустить версию, в которой действие открыто без права, будет остановлена на этапе проверок.

14. Тестирование и обеспечение качества

14.1. Уровни тестирования

Качество обеспечивается тремя уровнями автоматических тестов. Каждый уровень ловит свой класс ошибок, и ни один не заменяет остальные.

Таблица 14.1 — Состав автоматических тестов

Уровень	Инструмент	Объём	Что покрывает
Бэкенд-тесты, модульные и интеграционные	Штатное средство тестирования Go	2 096 тестов в 372 файлах	Обработку заявок, разграничение доступа, работу с данными, выгрузки, шифрование
Фронтенд-тесты	Vitest	4 618 тестов в 514 файлах	Поведение экранов и элементов, обработку данных на стороне браузера, хранилища состояния

Уровень	Инструмент	Объём	Что покрывает
E2E-сценарии, сквозные	Playwright	188 тестов в 47 файлах	Работу системы целиком в браузере от входа до результата, а также прямые обращения к программному интерфейсу
Всего		6 902	

Существенная особенность: бо́льшая часть бэкенд-тестов выполняется **на настоящей базе данных**, которая разворачивается специально для прогона, а не на её упрощённой замене. Это медленнее, но обнаруживает ошибки в запросах, ограничениях целостности и правах, которые упрощённая замена пропустила бы в принципе. Точное число таких файлов приведено в разделе 15.

E2E-сценарии запускаются в настоящем браузере и повторяют действия работника: заполнение формы заявки, приём в работу, отметку въезда на посту, открытие разделов администрирования.

Отдельно поддерживаются тесты, закрепляющие разграничение доступа: они пытаются выполнить действие без права и требуют получить отказ. Такие тесты не дают случайно открыть доступ при доработках.

14.2. Что дают тесты при сопровождении

Набор тестов нужен не сам по себе, а как страховка при внесении изменений. Практический эффект такой.

- Ошибка обнаруживается до выкладывания, а не пользователем на рабочем сервере.
- Доработка одной части системы, случайно сломавшая другую, будет остановлена: E2E-сценарии проходят по основным рабочим процессам целиком.
- Разграничение доступа защищено от случайного ослабления.
- Известные уязвимости в используемых библиотеках обнаруживаются автоматически, включая появившиеся уже после выпуска версии.

14.3. Автоматический конвейер сборки и проверки

Конвейер построен на GitHub Actions и запускается сам. Он состоит из трёх процессов с разными условиями запуска: это существенно, потому что не всё выполняется на каждое изменение.

Основной конвейер. Запускается на каждое изменение в основной ветке и на каждый запрос на слияние.

Таблица 14.2 — Этапы основного конвейера

Этап	Что выполняется
Определение изменений	Анализируется, какие части затронуты, чтобы не запускать лишнее
Проверка описания изменения	Описание проверяется на соответствие принятому формату
Статический анализ	Код серверной части проверяется на подозрительные конструкции
Бэкенд-тесты	Разворачивается база данных, тесты прогоняются с обнаружением состязаний за общие данные
Проверка стиля интерфейса	Код интерфейса проверяется на соответствие правилам оформления
Фронтенд-тесты	Прогон тестов интерфейса
Сборка образов	Собираются образы контейнеров, проверяется, что процесс внутри работает от непривилегированного пользователя, после чего проверенные образы помещаются в хранилище образов
Выкладывание на стенд	Только при попадании изменения в основную ветку: стенд забирает готовые образы из хранилища и перезапускается
Итоговый контроль	Отдельный этап, который завершается неудачей, если неудачей закончился любой предыдущий

Сквозные сценарии. Выполняются при запросе на слияние в основную ветку, если изменения затронули интерфейс или серверную часть. Прогон идёт в браузере на четырёх параллельных потоках, отчёт сохраняется при неудаче.

Сканирование уязвимостей. Выполняется на изменения в основной и производственной ветках, а также еженедельно по расписанию. Расписание нужно потому, что сведения об уязвимости часто появляются уже после выпуска версии, когда сама программа не менялась. Состав средств приведён в подразделе 13.10.

Изменение, не прошедшее основной конвейер, к выпуску не допускается: итоговый контроль перекрывает выпуск, если хотя бы один этап завершился неудачей.

Обновления используемых библиотек предлагаются автоматически, сгруппированные по назначению, и проходят те же проверки, что и остальные изменения.

14.4. Проверочный стенд

Помимо рабочего сервера поддерживается отдельный стенд с той же системой. Изменения попадают на него автоматически после успешного прохождения проверок, что позволяет посмотреть их вживую до выкладывания на рабочий сервер.

Интерфейс стенда закрыт запросом имени и пароля, который выдаёт обратный прокси до входа в систему; программный интерфейс отвечает по маркеру доступа, как и на рабочем сервере. База у стенда отдельная, поэтому эксперименты на нём не затрагивают рабочие данные, а рабочие персональные данные на стенд не переносятся.

Порядок работы со стендом и порядок выкладывания на рабочий сервер описаны в руководстве по развёртыванию и сопровождению.

15. Масштаб системы

Сведения приводятся для оценки объёма разработки и трудоёмкости сопровождения.

Таблица 15.1 — Количественные показатели

Показатель	Значение
Объём исходного кода	479 059 строк в 1 742 файлах
Серверная часть	102 453 строки без тестов: 186 служб, 75 обработчиков, 81 модель данных
Экраны и элементы интерфейса	199 296 строк: 39 экранов, 218 элементов
Методы программного интерфейса	511 в 39 группах
Таблицы базы данных	101
Автоматические тесты	6 902
Файлов бэкенд-тестов на настоящей базе	259

Объём исходного кода приведён по файлам серверной части и интерфейса вместе с тестами; сторонние библиотеки и сформированное из кода описание программного интерфейса в подсчёт не входят.

Конфигурация сервера, приведённая в руководстве по развёртыванию и сопровождению, рассчитана на 1000-1500 одновременно работающих пользователей. Значение получено расчётом по параметрам базы данных и прикладного сервера; нагрузочные испытания на целевом оборудовании подтвердят или уточнят его.

Приложение А. Категории прав доступа

Таблица А.1 — Категории прав

Категория	Содержание
Разделы навигации	Доступ к экранам системы
Элементы верхней панели	Действия, доступные из шапки
Центр заявок	Просмотр и обработка заявок, приём в работу, решения, дополнение поданной заявки
Карточки объектов	Просмотр карточек транспорта и людей, история
Реестры	Работа с реестрами людей и транспорта
Администрирование	Учётные записи, права, справочники, журналы, вход в систему от имени другого работника
Обзор и руководство	Доступ к разделам встроенной справки
Таблицы постов	Создаются автоматически для каждой таблицы: просмотр, отметки въезда и выезда, карточка, история, версии, выгрузка, отчёт по проходам, корзина, удаление

Категория администрирования не является одним правом: разделы внутри неё - справочники, учётные записи, настройки, журнал обращений к персональным данным, файловый архив, конструктор таблиц постов - закрыты каждый своим ключом и назначаются по отдельности, см. подраздел 4.2.

Два действия доступны исключительно супер-администратору: включение режима технических работ и назначение прав администратора.